

Healthcare Privacy and Data Protection

Giuseppe Pisano
g.pisano@unibo.it

Healthcare Data Privacy and Security

August, 2026



S.K.I.L.L.E.D — AID013244/04/2

Strategic Knowledge and Inclusive Lifelong Learning in the health sector for youth Employability and Development

- 1 From Privacy to Data Protection
- 2 Healthcare Data
- 3 Global Frameworks
- 4 GDPR Concepts
- 5 Principles and Legal Bases
- 6 Rights of Patients
- 7 Accountability and Design

8 Privacy Risks in Digital Healthcare

9 Final Integration

Learning path

We move from the idea of **privacy** as private life, to **data protection** as control over information, and finally to concrete duties for healthcare systems that process patient data.

Hospital storyline

St. Isidore Hospital wants to use electronic health records, laboratory systems, telemedicine, research datasets, and AI triage support. Each system may be useful, but each changes who can see, copy, combine, or infer sensitive information about patients.

Position of this lesson

The GDPR is used here as a detailed example of modern data protection law. It is influential globally, but it is not the only model.

Why it is useful

GDPR makes many core ideas explicit: personal data, processing, controller, processor, legal basis, purpose limitation, minimization, rights, accountability, data protection by design, breach duties, and supervision.

From Privacy to Data Protection

Section Context: From Privacy to Data Protection



What we are talking about

Privacy began as protection against unwanted intrusion into private life. In digital healthcare, the problem expands: patients may not only be watched; their data can be stored, linked, reused, exported, profiled, and breached.

Hospital lens

A doctor overhearing private symptoms in a corridor is a privacy problem. A database exporting lab results to an insurer without a valid reason is a data protection problem.

Origins: The Right to Be Let Alone

Classical idea

Modern privacy discourse is often traced to Warren and Brandeis and the idea of a right to be “let alone” [Warren and Brandeis, 1890]. This model protects private life, habits, writings, images, family life, and reputation from unjustified exposure.

Running example

If a hospital employee shares a celebrity patient’s ward photo with a newspaper, the harm is not only security failure. It is an invasion of private life and dignity.

Privacy as a Fundamental Right

Human-rights dimension

Privacy becomes more than a private-law claim. It protects autonomy, family life, correspondence, home, dignity, and democratic freedom. International and European instruments frame it as a right against arbitrary interference [United Nations, 1948, Council of Europe, 1950].

Running example

A public hospital is part of the state. If it centralizes patient records, the issue is not only employee curiosity; public power must also be constrained by law, necessity, and safeguards.

Decision Privacy and Information Privacy

Two faces

Decision privacy protects autonomy in intimate and family choices.

Information privacy protects control over the circulation of information about those choices.

Running example

A patient's decision to seek reproductive care involves decision privacy. The record of that visit, the prescription, billing code, and appointment reminder involve information privacy.

The Shift to Data Protection

Digital turning point

From the 1970s onward, privacy law increasingly focused on personal data. The key question becomes: who may collect, use, connect, retain, disclose, or delete information relating to a person?

Running example

St. Isidore Hospital may need to share data between emergency care and the laboratory. Data protection does not simply say “never share”; it asks whether the sharing has a purpose, a legal basis, limits, security, transparency, and accountability.

Privacy and Data Protection Scheme



Reading the scheme

Privacy protects private life. Data protection adds governance for the life cycle of information.

Recap: From Privacy to Data Protection

Takeaways

- Privacy is not only secrecy; it protects autonomy and dignity.
- Data protection focuses on the circulation and use of personal information.
- Healthcare needs controlled data sharing, not total data isolation.

In St. Isidore Hospital

St. Isidore must protect patients from exposure while still allowing data to move safely for care.

Healthcare Data

Section Context: Healthcare Data

What we are talking about

Healthcare data is especially sensitive because it can affect treatment, employment, insurance, family relations, stigma, and personal safety. Many laws treat health information as requiring stronger protection than ordinary administrative data.

Hospital lens

A patient phone number is personal data. A diagnosis, HIV test, pregnancy record, genetic marker, or mental-health note can expose intimate facts and future risks.

Personal Data and Medical Data

Distinction

Personal data identifies or can identify a person. **Medical data** is generated in care: symptoms, diagnoses, medication, tests, imaging, procedures, outcomes, and clinical notes.

Running example

The string “Maria Rossi” identifies a patient. “Positive malaria test”, “CD4 count”, or “post-operative infection” is medical data. Together, they become highly sensitive patient information.

PHI as a Practical Teaching Term

Protected health information

Healthcare privacy literature often uses **PHI** for information linked to a person's health status and care. The exact legal term differs by jurisdiction, but the operational idea is stable: health-linked identifiable data deserves enhanced safeguards [Conduah et al., 2025].

Running example

An appointment ID alone may look harmless. If it links to oncology, psychiatry, infectious disease, or maternity services, it can become sensitive.

Why Healthcare Data Is Hard to Protect

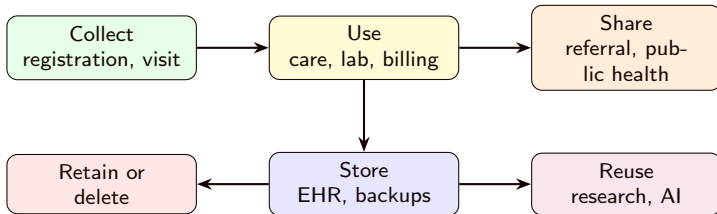
Practical tension

Healthcare data must be available quickly for treatment, but it must not become freely visible to everyone. Care delivery, billing, public health, quality control, and research all create pressure to reuse data.

Running example

In emergency care, a clinician needs allergies and medication history immediately. A marketing contractor does not need the same access to the same record.

Healthcare Data Life Cycle



Recap: Healthcare Data

Takeaways

- Health data can identify, stigmatize, and harm patients.
- Sensitivity often comes from context and linkage, not only from one field.
- Privacy controls must follow the whole data life cycle.

In St. Isidore Hospital

St. Isidore must ask not only “who can open the EHR?” but also “where does the data go next?”

Global Frameworks

Section Context: Global Frameworks

What we are talking about

Data protection rules differ across countries, but many share a family resemblance: lawful collection, purpose limitation, data quality, security, individual rights, accountability, and rules for cross-border flows.

Hospital lens

A patient may be treated locally, tested by an external laboratory, followed through a cloud telemedicine platform, and included in international research. Privacy rules must travel with that workflow.

International Building Blocks

Common roots

The Universal Declaration of Human Rights, the European Convention on Human Rights, Council of Europe Convention 108, and OECD Privacy Guidelines helped shape modern privacy and data protection thinking [United Nations, 1948, Council of Europe, 1950, Council of Europe, 1981, OECD, 2013].

Running example

Even before choosing a specific law, St. Isidore Hospital can recognize baseline principles: avoid arbitrary interference, define purposes, limit collection, protect security, and allow people some control.

Why GDPR Became a Reference Model

Global influence

GDPR combined broad territorial reach, strong rights, accountability, security duties, independent supervision, and cross-border transfer rules. Its structure has influenced policy debates and many regulatory reforms, even outside Europe [European Union, 2016, European Commission, 2026].

Careful wording

GDPR is not copied everywhere. Some systems focus on sectors, consumers, constitutional privacy, public health, or cyber duties. It is best treated as a mature reference architecture, not as a universal template.

Regulatory Fragmentation

Problem

Global healthcare privacy is difficult because definitions, enforcement capacity, security expectations, breach reporting, consent rules, and infrastructure differ across jurisdictions [Conduah et al., 2025].

Running example

If St. Isidore joins a multicountry malaria study, one partner may require ethics approval and pseudonymization, another may require local storage, and a cloud tool may trigger transfer rules.

Recap: Global Frameworks

Takeaways

- GDPR is a strong reference example, not the only privacy law.
- Many regimes share principles, but implementation differs.
- Cross-border healthcare workflows need legal and technical interoperability.

In St. Isidore Hospital

St. Isidore cannot solve privacy by naming one law; it must map data flows and applicable duties.

GDPR Concepts

Section Context: GDPR Concepts

What we are talking about

GDPR gives vocabulary that is useful beyond Europe: personal data, processing, data subject, controller, processor, principles, legal basis, special categories, rights, and accountability.

Hospital lens

These words help translate a messy hospital workflow into governance questions: who decides, who acts, why data is used, how much is needed, and how patients can exercise control.

Personal Data and Identifiability

Core idea

Personal data is any information relating to an identified or identifiable natural person. A person may be identified directly, or indirectly through identifiers, location, online IDs, or physical, genetic, economic, cultural, social, or other characteristics [European Union, 2016].

Running example

“Patient 1042” may still be personal data if the hospital can link that number to a name. A rare disease plus village plus admission date may also identify someone indirectly.

The Identifiability Test

Reasonable means

Identifiability depends on what the controller or another party can reasonably use, considering cost, time, available technology, and likely future developments.

Running example

A dataset with ages, postal codes, rare diagnoses, and dates may look anonymous. If local staff can match it with appointment schedules, it may still identify patients.

Anonymization vs Pseudonymization

Different risk levels

Anonymization aims to make re-identification no longer reasonably possible. **Pseudonymization** replaces direct identifiers with codes, but someone can still re-link the data using additional information.

Running example

Removing names from lab results is not enough if a separate key links code P-1042 to Maria. That is pseudonymized data, not anonymous data.

Processing Means Almost Everything

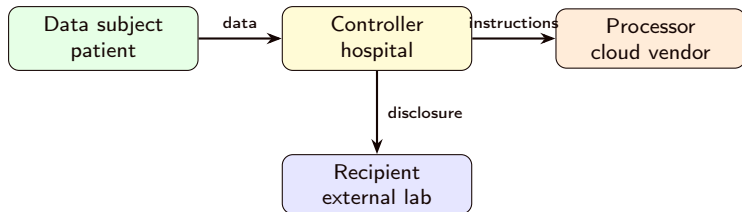
Processing

Processing includes collecting, recording, organizing, storing, changing, consulting, using, transmitting, making available, comparing, linking, restricting, erasing, and destroying data.

Running example

When a nurse opens a record, a lab uploads a result, a backup stores the database, or a research team receives an export, each action is processing.

Actors in a Data Processing Workflow



Controller and Processor

Responsibility structure

The **controller** determines purposes and means. The **processor** processes personal data on behalf of the controller. Joint controllers may exist when multiple parties jointly decide why and how processing happens.

Running example

St. Isidore Hospital decides to use an EHR for patient care: it is the controller. A hosting provider that runs the database under hospital instructions is usually a processor.

GDPR Object, Scope, and Balance

Object

GDPR protects natural persons with regard to personal-data processing and also supports free movement of personal data within the EU. It balances data protection, legitimate data flows, and other rights such as information, research, and non-discrimination.

Running example

A hospital should not block every data transfer in the name of privacy. It should allow necessary care, public health, and research flows under defined safeguards.

Recap: GDPR Concepts

Takeaways

- Personal data depends on identifiability, including indirect identifiability.
- Pseudonymized data can still be personal data.
- Governance starts by naming actors, purposes, and processing operations.

In St. Isidore Hospital

St. Isidore can now describe a patient-data workflow before deciding whether it is lawful or safe.

Principles and Legal Bases

Section Context: Principles and Legal Bases

What we are talking about

Modern data protection law does not only ask whether data is secret. It asks whether processing is lawful, fair, transparent, purpose-bound, minimized, accurate, time-limited, secure, and demonstrably governed.

Hospital lens

The same patient record may be lawful for treatment, unlawful for curiosity, and risky for research unless it is governed by an appropriate legal basis and safeguards.

Principles of Processing

Principle	Hospital question
Lawfulness, fairness, transparency	Why can we use this data, and has the patient been informed?
Purpose limitation	What exact care, billing, research, or public-health purpose?
Data minimization	Which fields are necessary?
Accuracy	Is the allergy, diagnosis, or contact data correct?
Storage limitation	How long do we keep it?
Integrity and confidentiality	Who can access it, and how is it secured?
Accountability	Can we prove our controls and decisions?

Legal Bases: Consent Is Only One Option

Lawfulness

GDPR lists several legal bases: consent, contract, legal obligation, vital interests, public task, and legitimate interests. Healthcare often relies on legal obligation, public interest, vital interests, or healthcare-specific grounds, not only consent.

Running example

An unconscious patient cannot meaningfully consent in the emergency room. Treatment may still be necessary to protect vital interests and deliver care under health-system rules.

Consent: Strong but Fragile

Elements

Consent must be freely given, specific, informed, and unambiguous. For sensitive data, explicit consent may be required in some contexts, but health law may also provide other grounds.

Running example

“Accept all hospital data uses” is not specific. Separate choices may be needed for appointment reminders, research contact, patient portal analytics, or optional wellness programs.

Why Online Consent Often Fails

Practical weakness

Online consent may be bundled, manipulated by interface design, poorly understood, hard to refuse, or harder to withdraw than to give. Notice-and-consent alone is weak when patients face power imbalances or urgent care needs.

Running example

A patient should not be forced to accept marketing analytics in order to book an essential oncology appointment.

Special Categories: Health Data

Higher protection

Data revealing health, genetics, biometrics used for unique identification, sex life, or other special categories is generally subject to a prohibition unless a specific exception applies.

Running example

The hospital may process blood-test results for care, but reuse for AI product development needs a separate legal and ethical analysis.

Recap: Principles and Legal Bases

Takeaways

- Principles turn privacy into operational design questions.
- Consent is important, but healthcare cannot be reduced to consent banners.
- Health data usually needs stronger safeguards and clearer justification.

In St. Isidore Hospital

St. Isidore must document why each data use exists and why the chosen data is necessary.

Rights of Patients

Section Context: Rights of Patients

What we are talking about

Data protection gives people enforceable rights over information about them. In healthcare, those rights must be handled carefully because records also support safety, continuity of care, legal retention, and professional accountability.

Hospital lens

A patient asking for a copy of their record is not making an IT request. They are exercising control over information that may shape future care and personal life.

Core Rights

Right	Hospital meaning
Information Access	clear privacy notice and explanation of purposes know whether data is processed and obtain relevant information
Rectification	correct inaccurate data and complete incomplete data
Erasure	delete data when grounds apply, subject to limits
Restriction	pause certain processing while issues are resolved
Portability	receive and transfer data in structured format where applicable
Objection	object to certain public-task or legitimate-interest processing
Automated decisions	protections against solely automated significant decisions

Information and Access

Transparency in practice

Patients should know who processes data, for which purposes, on what legal basis, who receives it, how long it is kept, whether automated decisions exist, and how to exercise rights.

Running example

If St. Isidore Hospital sends samples to an external laboratory, the privacy notice should not hide that relationship behind vague wording such as “trusted partners”.

Rectification and Clinical Safety

Accuracy matters

The right to rectification reflects the principle of accuracy. In healthcare, wrong data can cause direct physical harm, not only privacy harm.

Running example

If the EHR wrongly records that a patient has no penicillin allergy, rectification is a safety control. If it records the wrong phone number, confidentiality can also fail.

Erasure and Its Limits

Not a simple delete button

Erasure may apply when data is no longer necessary, consent is withdrawn and no other basis exists, or processing is unlawful. But healthcare records may also be subject to legal retention, medical liability, public-health, or patient-safety duties.

Running example

A patient may ask to delete marketing preferences. Deleting a surgical record needed for continuity of care is a different question.

Automated Decisions and Profiling

High-stakes automation

Profiling uses personal data to evaluate or predict aspects of a person, including health, behavior, reliability, or location. Solely automated decisions with significant effects require special safeguards.

Running example

An AI triage tool may support a clinician. A fully automated refusal of specialist referral based on a risk score would require close legal, ethical, and clinical scrutiny.

Recap: Rights of Patients

Takeaways

- Rights make privacy operational for patients.
- Healthcare rights must be balanced with safety and lawful retention.
- Automated systems need transparency, human oversight, and contestability.

In St. Isidore Hospital

St. Isidore needs workflows for rights requests, not just a privacy policy page.

Accountability and Design

Section Context: Accountability and Design

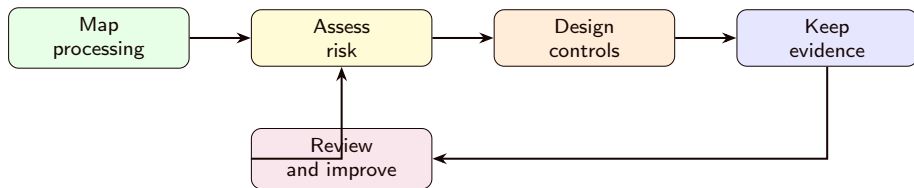
What we are talking about

GDPR's philosophy is accountability: the controller must choose appropriate technical and organizational measures and be able to prove them. Compliance is not only paperwork; it is design, operation, monitoring, and review.

Hospital lens

If a breach occurs, St. Isidore Hospital must explain what data was processed, why, who had access, which controls existed, how risks were assessed, and what changed after the incident.

Accountability Architecture



Data Protection by Design and by Default

Design rule

Privacy must be built into systems when purposes and means are chosen, and during processing. Default settings should process only the data necessary for each purpose, with limited access, scope, retention, and visibility.

Running example

The laboratory dashboard should default to lab requests and results, not the full psychiatric and billing history of every patient.

Technical and Organizational Measures

Measure	Healthcare example
Access control	roles for clinicians, lab, admin, researcher
Encryption	protect laptops, backups, APIs, and data transfers
Pseudonymization	research exports separated from direct identifiers
Logging and audit	detect unusual access to celebrity or staff records
Retention rules	keep records as required, delete optional data sooner
Training and policy	staff know when sharing is legitimate
Vendor governance	processor contracts and security requirements

Breach Notification and DPIA

Risk-triggered duties

Some obligations depend on risk: personal-data breaches may require notification to a supervisory authority and, in higher-risk cases, communication to affected people. High-risk processing may require a Data Protection Impact Assessment.

Running example

A lost encrypted laptop may be low risk if keys are safe. A leaked spreadsheet of identifiable HIV results is high risk and demands urgent legal, technical, and patient-support action.

DPO and Supervisory Authorities

Oversight

Modern data protection often includes independent supervisory authorities and, in some organizations, a Data Protection Officer. Their role is to help ensure that privacy duties are not left to ad hoc technical judgment alone.

Running example

When St. Isidore Hospital plans an AI triage pilot, the DPO, clinicians, security team, and ethics board should be involved before deployment.

Recap: Accountability and Design

Takeaways

- Accountability means choosing controls and proving they work.
- By design and by default connects privacy to system architecture.
- Breach response and DPIA are risk-management tools.

In St. Isidore Hospital

St. Isidore turns privacy from a document into a repeatable governance process.

Privacy Risks in Digital Healthcare

Section Context: Digital Healthcare Risks

What we are talking about

Electronic records, cloud services, APIs, analytics, mobile apps, and AI increase both care value and privacy risk. Security failures, poor governance, and unclear data flows can all undermine patient trust.

Hospital lens

The same API that helps the emergency department retrieve records quickly can also expose large volumes of patient data if authentication, authorization, logging, or contracts fail.

Breach Examples

What major incidents teach

Large healthcare breaches and disruptions, including Anthem, WannaCry/NHS, SingHealth, and other regional incidents, show that legal frameworks alone cannot protect data without resilient systems, patching, segmentation, backups, monitoring, and governance [Conduah et al., 2025].

Running example

If ransomware blocks laboratory results, privacy, safety, and availability fail together. Patients are harmed even if no one reads the data.

Privacy, Security, and Trust

Relationship

Security is not identical to privacy, but privacy depends on security. Confidentiality, integrity, and availability protect patient data so that information is not exposed, corrupted, or unavailable when care depends on it.

Running example

Encryption protects confidentiality. Audit logs support accountability. Backups protect availability. All three contribute to patient trust.

Emerging tools

AI and machine learning can support anomaly detection, risk prediction, and compliance monitoring. Blockchain can support integrity and traceability in some sharing scenarios. But tools can also create new data flows, inference risks, and accountability questions.

Running example

An AI model that detects unusual EHR access is useful. An AI model trained on excessive patient details without a valid purpose creates a new privacy problem.

From Previous Lessons to Privacy

Previous topic	Privacy connection
Networking	segment systems so not every subnet can reach every API
Authentication	know who is accessing patient data
Access control	limit users to legitimate roles and tasks
Encryption	protect data at rest and in transit
Logging	produce evidence of access, changes, and incidents

Recap: Privacy Risks in Digital Healthcare

Takeaways

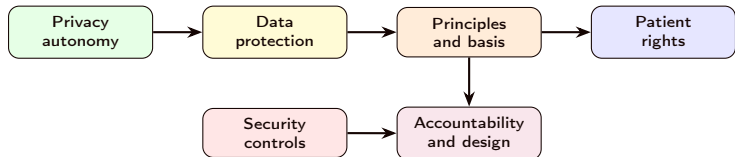
- Digital healthcare privacy is legal, ethical, and technical.
- Breaches show that compliance language is not enough.
- Security controls become privacy safeguards when tied to purpose and rights.

In St. Isidore Hospital

St. Isidore's earlier security controls now become part of patient-data protection.

Final Integration

Final Concept Map



Final Recap



Core lesson

Healthcare privacy is not only confidentiality. It is the governance of identifiable health data throughout its life cycle: lawful purpose, minimal use, transparency, patient rights, security, accountability, and evidence.

In St. Isidore Hospital

St. Isidore can use EHRs, APIs, labs, research datasets, and AI tools, but each data flow must have a reason, a limit, a safeguard, and someone accountable for it.

References I

[Conduah et al., 2025] Conduah, A. K., Ofoe, S., and Siaw-Marfo, D. (2025).

Data privacy in healthcare: Global challenges and solutions.
Digital Health, 11:1–19

DOI:10.1177/20552076251343959.

[Council of Europe, 1950] Council of Europe (1950).
European convention on human rights

<https://www.echr.coe.int/european-convention-on-human-rights>.

[Council of Europe, 1981] Council of Europe (1981).
Convention 108 and protocols

<https://www.coe.int/en/web/data-protection/convention108-and-protocol>.

References II

[European Commission, 2026] European Commission (2026).
Legal framework of eu data protection

https://commission.europa.eu/law/law-topic/data-protection/legal-framework-eu-data-protection_en.

[European Union, 2016] European Union (2016).
Regulation (eu) 2016/679, general data protection regulation

<https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng>.

[OECD, 2013] OECD (2013).
Oecd privacy guidelines

<https://legalinstruments.oecd.org/public/doc/114/body-text.en.html>.

[United Nations, 1948] United Nations (1948).
Universal declaration of human rights

<https://www.un.org/en/about-us/universal-declaration-of-human-rights>.

References III

[Warren and Brandeis, 1890] Warren, S. D. and Brandeis, L. D. (1890).
The right to privacy.
Harvard Law Review, 4(5):193–220

.